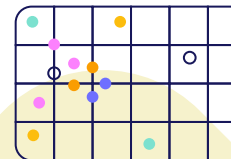


Master 2 Cybersécurité Projet VET

SOC IA Orange

Masha Mirza Zad Ziabary | Abdullah Ahmed-Bark
Swailem | Mirwis Satarzai | Damien Maris



Rappel problématique :

- ◆ **Comment un assistant SOC peut-il aider à faire la distinction entre les vulnérabilités réellement critiques et les vulnérabilités théoriques ?**

Sommaire



01.

Vulnerable Exploitation Tool

architecture/tools/rag

02.

Architecture de simulation : Génération des logs

Infrastructure - Outils - Logs

03.

Ingestion des Données (DB & Logs)

bdd/vectorstor

04.

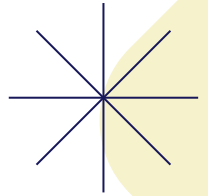
VMC & XGboost

CVE / CVSS / EPSS

05.

Vulnerable Exploitation Tool

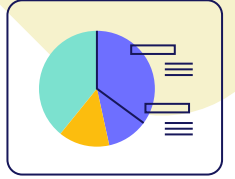
amélioration contextuelle



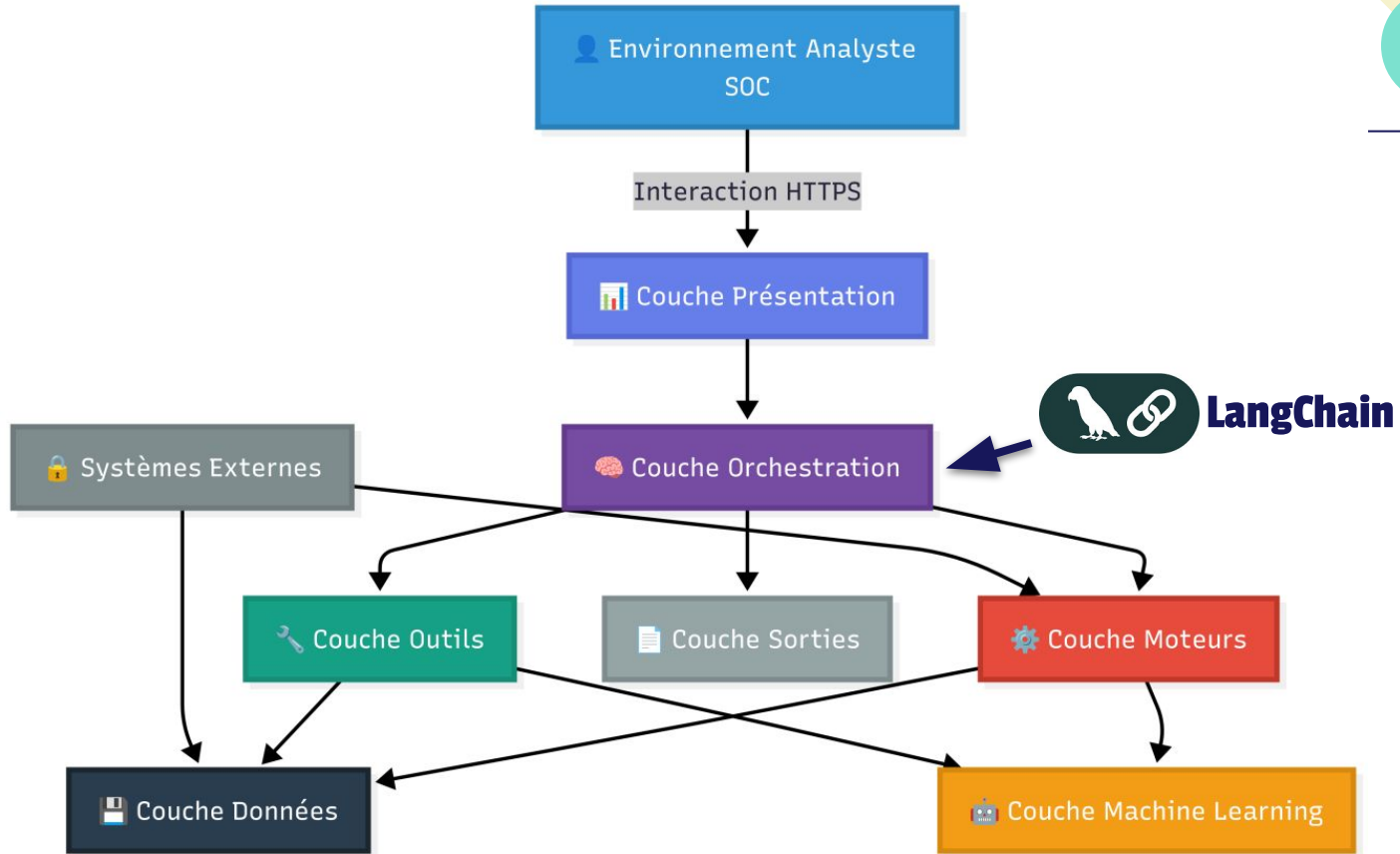
01.

Vulnerable Exploitation Tool

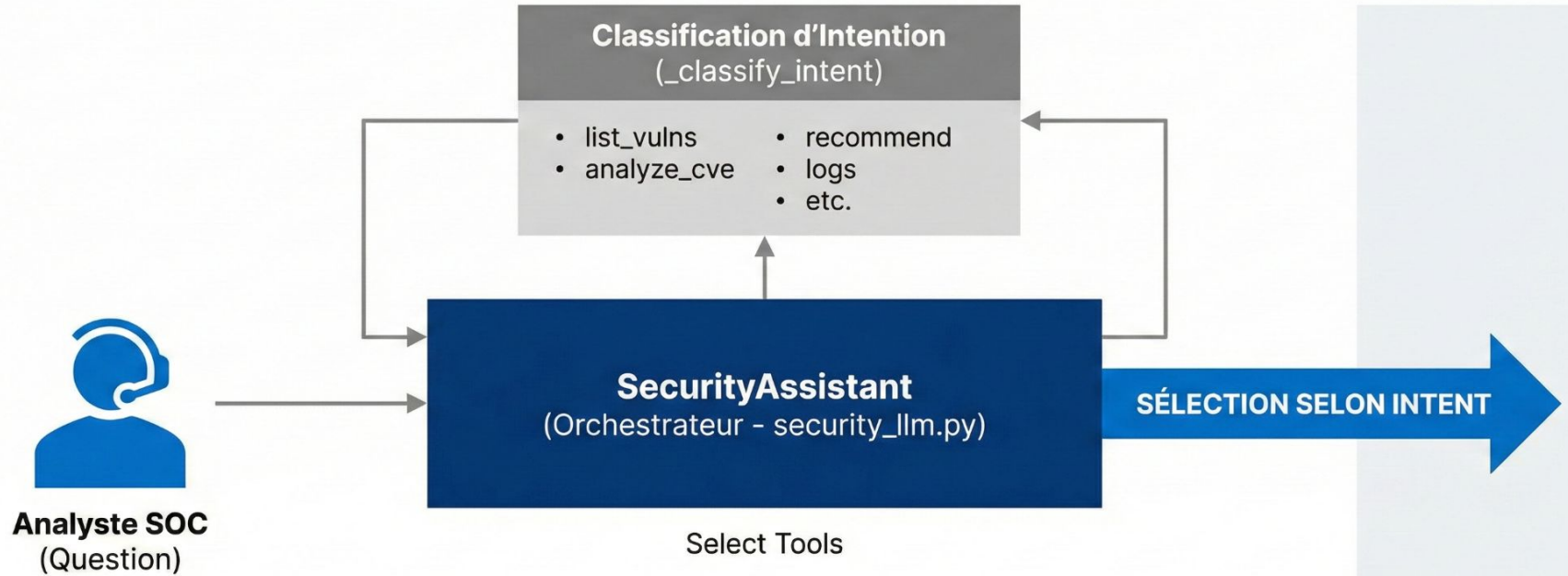
architecture/tools/rag



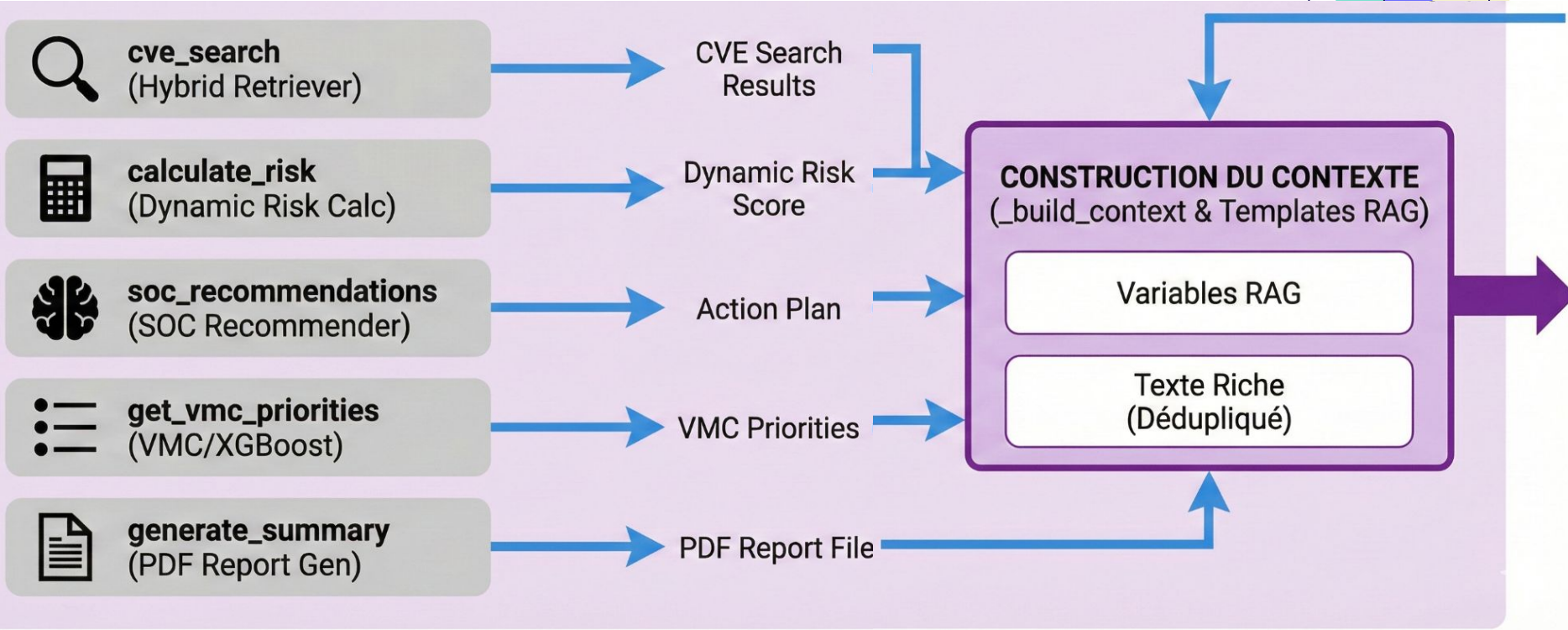
a. Architecture



b. Réception de la question et décision d'activation des outils.



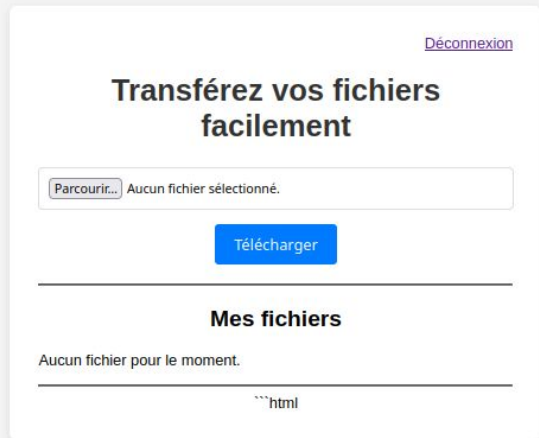
c. Exécution des Outils & Construction du Contexte



02.

Architecture de simulation : Génération des logs

Infrastructure - Outillage - Logs



A screenshot of a web application interface for file uploads. At the top right is a link labeled 'Déconnexion'. The main heading is 'Transférez vos fichiers facilement'. Below it is a file selection area with a 'Parcourir...' button and the text 'Aucun fichier sélectionné.'. A blue 'Télécharger' button is positioned below the selection area. A horizontal line separates this from the 'Mes fichiers' section. Under 'Mes fichiers', it says 'Aucun fichier pour le moment.' and shows a file icon with the name '""html'.

Infrastructure du serveur vulnérable simulé

Docker → environnement malléable et aisément configurable → OS plus suivi (Ubuntu 18.04)

Architecture web → Apache + Flask →
Multiples vulnérabilités logiques → CWE

Services obsolètes (MySQL 5.7, SMBv1, Tomcat 8.5) → multiples vulnérabilités architecturales → CVEs



Gestion des logs



Type de logs :

- **Applicatif Web**
→ tentatives d'injections, traces de scans...
- **Transfert de fichiers**
→ exfiltration de données, tentatives de connexion
- **Système & Sécurité**
→ intrusions, privesc, persistance



Source des logs :



- Apache
- Gunicorn
- Flask
- VSFTPD
- systemd-journald
- rsyslog / syslog
- Auditd
- MySQL
- Netstat
- ps



Génération d'activité et scans -> Logs

- Simulation d'activité
- Génération de trafic réel (curl)
- Lancement de scripts de scan (nmap,nikto)
- Outils pour générer du trafic (OWASP ZAP)
→ Honeypot obvious pour faciliter l'outil



- Génération des multiples logs
- Logs normalisés grâce à pyGrok
 - Pattern matching
 - Format json
 - Ingestion IA aisée

⚠ Zone de Test de Vulnérabilités (HoneyPot ZAP)

Ces liens existent pour permettre au scanner de découvrir les endpoints vulnérables.

GET Endpoints (Injections, IDOR, SSRF)

- [Admin Panel \(Broken Access Control\)](#)
- [Debug Users \(Info Disclosure\)](#)
- [Network Ping \(Command Injection\)](#)
- [Url Fetcher \(SSRF\)](#)
- [Search \(Reflected XSS\)](#)
- [Welcome Path \(Path XSS\)](#)
- [File Direct \(IDOR\)](#)
- [Backup File \(Source Disclosure\)](#)
- [API Config \(Hardcoded Creds\)](#)
- [Download Any \(Path Traversal\)](#)
- [Redirect \(Open Redirect\)](#)
- [HTML Comments \(Info Disclosure\)](#)
- [CORS Endpoint \(Misconfig\)](#)
- [Set Weak Cookies](#)
- [Guestbook \(Stored XSS\)](#)
- [No CSP Page](#)
- [File Read \(Null Byte\)](#)
- [Weak Crypto \(MD5\)](#)
- [Clickjacking Widget](#)
- [HPP Test](#)

POST Forms (Scanner Entry Points)

Analyse des vulnérabilités trouvées par scan

Nécessité de rapports pour comparer ce qui a été implémenté en théorie et ce qui est visible en pratique pour exploiter.

3 technologies utilisées :

- OWASP ZAP → Vu d'attaquant
- OpenVas - *Greenbone* → Scan plus réseau
- Trivy (SCA) → Scan de l'image docker



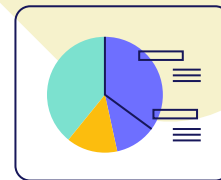
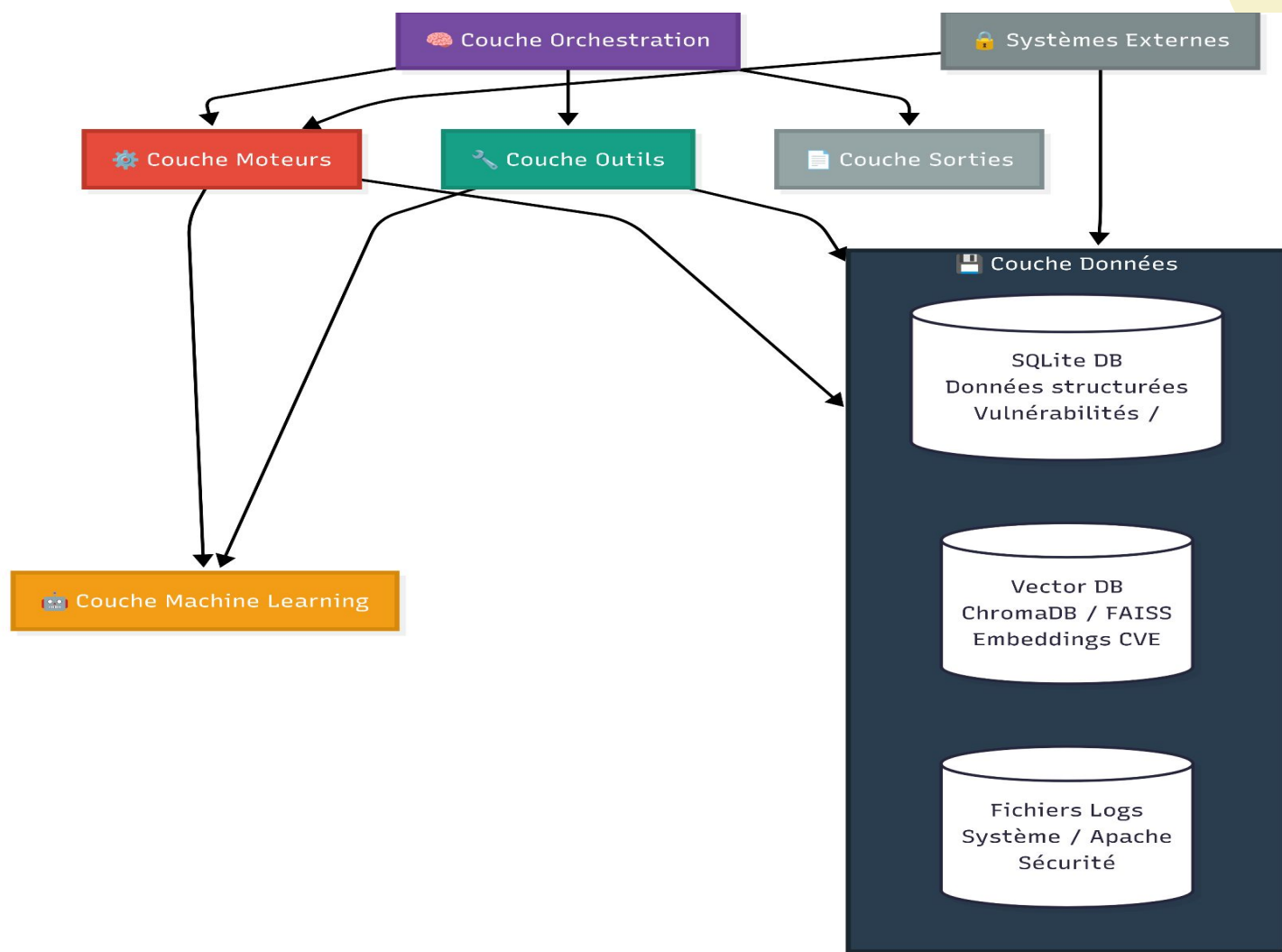
Ce qui a été trouvé

- 175 vulnérabilités (CVE) trouvées (25 gardées)
- Injection SQL - RFI - Injection de Commande - Failles XSS et SSTI ...
- RCEs (DistCC) - Mauvaises configs login ssh, redis, ftp, telnet

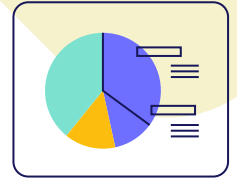
03.

Ingestion des Données (DB & Logs)

cve_database.db - utils/vectorstore.py



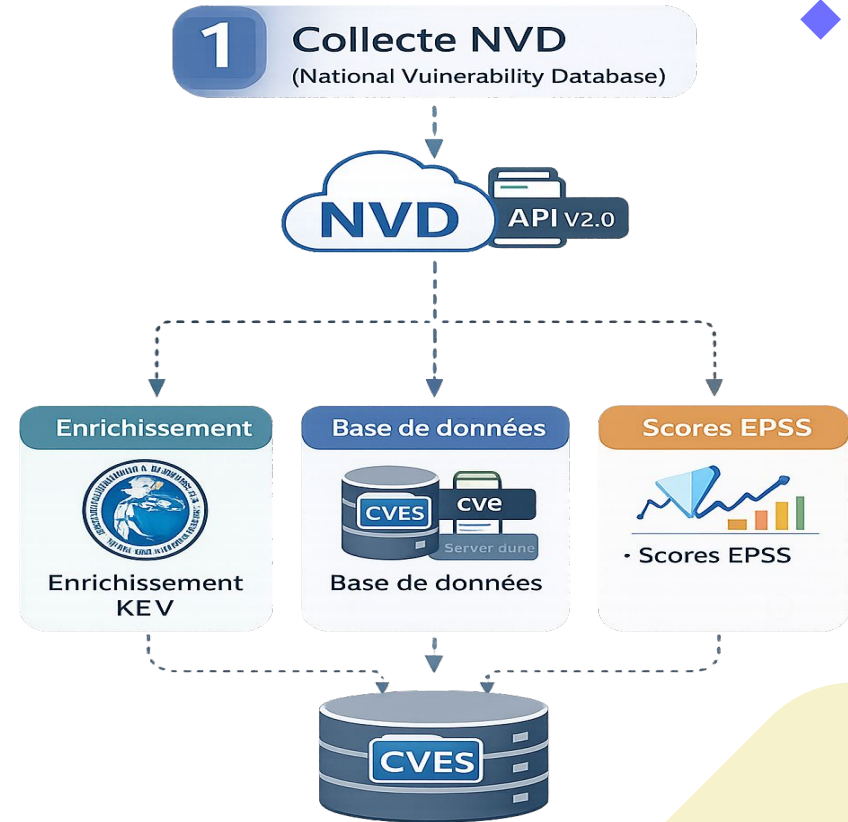
Structure de la Base (SQLite)



1. CVE : La table centrale qui contient toutes les informations techniques (ID, description, scores, etc.).
2. Server-Vulnerability: Une table de liaison pour suivre quelles CVE infrastructure. fectant quels serveurs dans notre

1. Common Vulnerabilities and Exposures

- Collecte NVD (National Vulnerability Database) :
Filtrage par mots-clés → liées aux serveurs HTTP/Web
- Enrichissement KEV (Known Exploited Vulnerabilities)
- Scores EPSS (Exploit Prediction Scoring System)



2. Server-Vulnerability Mapping

- Outil externe "Trivy "
- généralement au format XML
- Parsing : lit le fichier XML et extrait chaque ID de vulnérabilité .
- Stocker dans le server_vulns db
- Utiliser ce database pour le dashboard



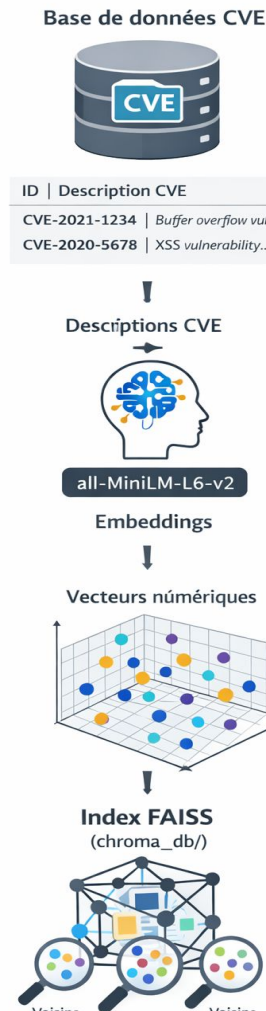
Indexation Vectorielle (RAG)

1. Transformer les mots en "coordonnées"

- **All-MiniLM-L6-v2** transforme chaque description de CVE en une liste de nombres (un vecteur)

1. FAISS : La bibliothèque ultra-rapide

- FAISS (Facebook AI Similarity Search)



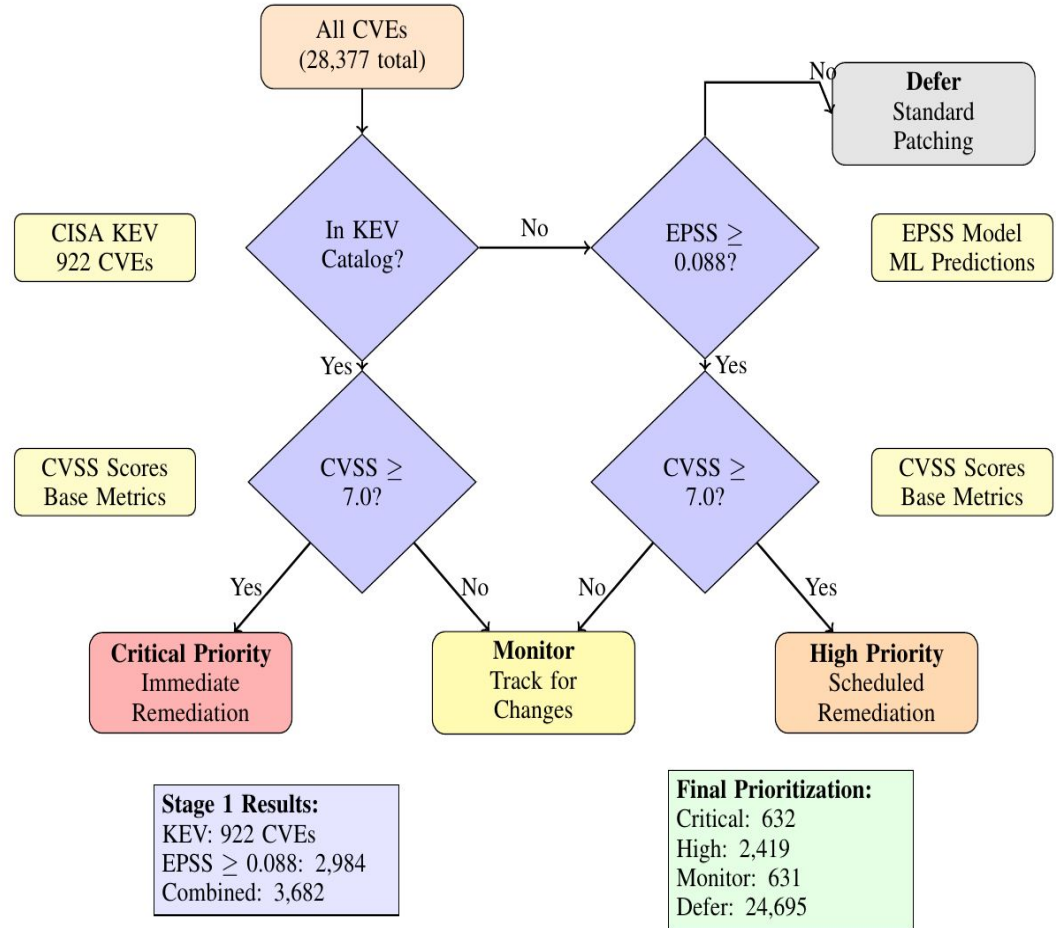
04.

VMC & XGboost

CVE / CVSS / EPSS

framework Vulnerability Management Chaining (VMC):

- **CVSS:** Common Vulnerability Scoring System
- **EPSS:** Exploit Prediction Scoring System
- **KEV:** Known Exploited Vulnerabilities



Architecture Technique VMC + XGBoost

Base de Données (SQLite)

CVE + EPSS + KEV

Priority Engine

priority_engine.py

- ✓ Charge CVE depuis DB
- ✓ Arbre décision VMC
- ✓ Score 0-100 (CVSS+EPSS+KEV)
- ✓ Classification priorité baseline

Scores VMC

Train data

ML Layer

data_engine.py

- ✓ XGBoost Model
- ✓ 5 features principales :
 - CVSS score
 - EPSS score
 - in_kev (0/1)
 - Vendor encodé
 - Type vulnérabilité (RCE, SQLi...)

Prédictions ML

VMC Tool (Orchestrateur)

vmc_tool.py

- ✓ Appelle Priority Engine
- ✓ Enrichit avec prédictions XGBoost
- ✓ Format variables RAG pour LLM
- ✓ Génère réponse structurée
- ✓ Tri des Top N vulnérabilités

Assistant SOC (LLM) - Interface conversationnelle

Priority_Engine

TRAITEMENT :

- **Base (40%):** $CVSS \times 4$
- **Menace (40%):** +20 si KEV & $+(EPSS \times 20)$
- **Contexte (20%):** +10 si RCE & +5 criticité serveur

Classification:

- $\geq 90 \rightarrow$  Critique
- $\geq 70 \rightarrow$  Haute
- $\geq 40 \rightarrow$  Moyenne
- $< 40 \rightarrow$  Faible

Base de Données (SQLite)

CVE + EPSS + KEV



Priority Engine

priority_engine.py

- ✓ Charge CVE depuis DB
- ✓ Arbre décision VMC
- ✓ Score 0-100 (CVSS+EPSS+KEV)
- ✓ Classification priorité baseline

Scores VMC

Data_Engine

FONCTIONNEMENT:

- Génère des labels via règles simples (VMC)
- XGBoost apprend ces décisions
- Classification en 4 niveaux

PRÉDICTION:

- Analyse + score de confiance
- Si confiance < 80% → ajoute avis règles simples
- L'analyste compare les deux opinions

Train data



ML Layer

data_engine.py

- ✓ XGBoost Model
- ✓ 5 features principales :
 - CVSS score
 - EPSS score
 - in_kev (0/1)

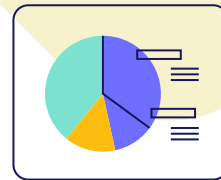
- Vendor encodé
- Type vulnérabilité
(RCE, SQLi...)

Prédictions ML

05.

Vulnerable Exploitation Tool

amélioration contextuelle



Génération structurée avec Llama 3.1 et Pydantic

Schéma Pydantic Citble



```
class CVEItem(BaseModel):  
    cve_id: str = Field(..., description="CVE ID EXACT du contexte (ex: CVE-2022-XXXX)")  
    risk_level: str = Field(..., description="Niveau (CRITIQUE, HAUT, MOYEN, FAIBLE) - Copier  
exactement du contexte")  
    epss: float = Field(..., description="Score EPSS (float) - Copier exactement du contexte")
```

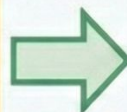


Llama 3.1
8B



Réponse LLM (JSON Brut)

```
{  
  "cve_id": "CVE-2023-XXXX",  
  "risk_level": "CRITIQUE",  
  ...  
}
```



PydanticOutputParser & Formatage



Llama 3.1
8B



Réponse Finale (Langage Naturel)

Analyse de
CVE-2023-XXXX :
Risque CRITIQUE...

LLM (Génération NL)

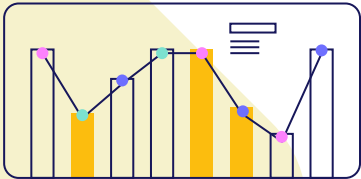
Conclusion

Obstacles :

- Fiabilité des réponses (Hallucinations - intention → pertinence outil)
- Fluidité du dialogue
- Cloisonnement imparfait

Améliorations :

- Human In The Loop - Feedback
- Meilleure orchestration avec LangGraph
- Optimisation et modèle plus puissant



Vulnérabilités Intentionnelles - FileTransferLike

1. Vulnérabilités d'Infrastructure (Docker / Système)

Ces vulnérabilités sont présentes au niveau du système d'exploitation du conteneur `getmynote-server`. (Total: 21)

ID	Vulnérabilité (CVE/CWE)	Port/Service	Description
INF-01	DistCC RCE (CVE-2004-2687)	3632/TCP	Exécution de commandes arbitraires via le démon de compilation distribuée.
INF-02	Tomcat Ghostcat (CVE-2020-1938)	8009/TCP	Lecture de fichiers arbitraires et RCE via protocole AJP.
INF-03	Redis Unprotected (CWE-306)	6379/TCP	Base de données NoSQL exposée sans authentification (Bind 0.0.0.0).
INF-04	Samba SMBv1 (CVE-2017-0144)	445/TCP	Configuration vulnérable à EternalBlue + Partage inscriptible (SambaCry).
INF-05	VSFTPD Backdoor (CVE-2011-2523)	6200/TCP	Backdoor Python simulant la faille : accès root sur port 6200.
INF-06	Shellshock (CVE-2014-6271)	HTTP Headers	Bash obsolète vulnérable aux injections via variables d'environnement.
INF-07	Struts2 S2-045 (CVE-2017-5638)	8080/TCP	RCE via Header <code>Content-Type</code> sur l'app Tomcat.
INF-08	WebLogic T3 RCE (Simulé)	7001/TCP	Simulation de service vulnérable à la désérialisation Java.
INF-09	Elasticsearch RCE (CVE-2014-3120)	9200/TCP	Simulation de l'exécution de script Groovy sandbox bypass.
INF-10	Telnet Cleartext (CWE-319)	23/TCP	Service Telnet non chiffré exposé via Xinetd.
INF-11	Heartbleed (CVE-2014-0160)	N/A	OpenSSL 1.0.1f compilé manuellement vulnérable au vol de mémoire.
INF-12	SSH Root Login (CVE-2018-15473)	22/TCP	SSH autorise root + mots de passe vides + énumération utilisateurs.
INF-13	TFTP Writable (CVE-2018-1111)	69/UDP	TFTP permet l'upload de fichiers arbitraires sans auth.
INF-14	NFS No Root Squash (Misconfig)	2049/TCP	Partage NFS montable avec droits root complets sur le serveur.
INF-15	Sudo NOPASSWD (CVE-2021-3156)	Ligne de com.	Utilisateurs <code>user</code> et <code>admin</code> peuvent passer root sans mot de passe.
INF-16	Insecure Permissions (PrivEsc)	FS Local	<code>/etc/passwd</code> , <code>/etc/shadow</code> en 777 (modifiables par tous).
INF-17	Weak Passwords (CWE-521)	Auth	Comptes <code>admin:admin123</code> et <code>user:user</code> présents.
INF-18	SNMP Public (CVE-1999-0517)	161/UDP	Communauté SNMP <code>public</code> par défaut (info disclosure).
INF-19	Anonymous FTP (CWE-284)	21/TCP	VSFTPD autorise upload et création de dossier en anonyme.
INF-20	Netcat Backdoor (Misconfig)	Ligne de com.	Binaire <code>nc</code> avec option <code>-e</code> disponible (reverse shell facile).
INF-21	PHP Webshell (Backdoor)	80/TCP	Webshell <code>/shell.php</code> pré-installé sur le serveur Web.